

# 第三讲 安全需求及安全策略

## 启动阶段的目标

➤根据业务流程、系统功能、目标用户、工作环境等，定义系统的需求；

➤明确约束条件，包括场地、设备、经费、人员等；

➤起草一份针对系统的安全策略。

• 这是这一阶段必不可少的部分，是构建一个可信系统的基础。

在项目启动阶段进行安全设计，而不是在实现或维护阶段

➤ 后来加上的服务包和补丁会带来新的漏洞

➤ 容易陷入补丁、修复、再补丁的恶性循环

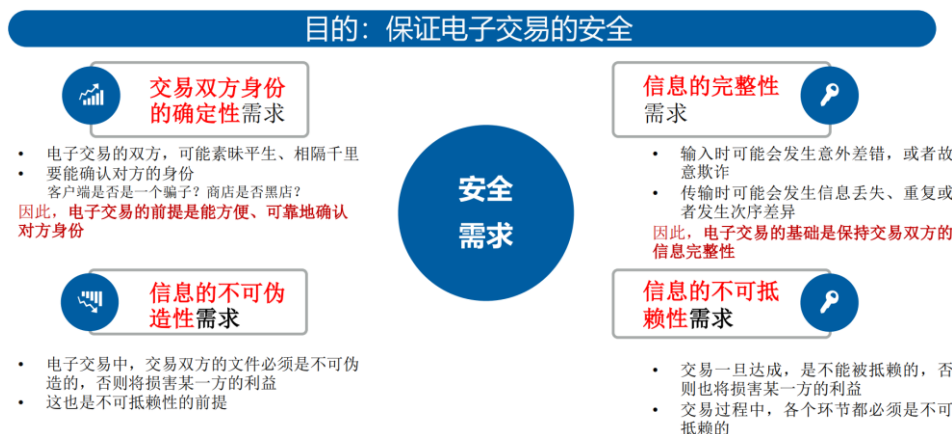
## 一、什么是安全需求？

### 1、安全需求的定义

安全需求就是在设计一个安全系统时期望得到的安全保障。

不同的用户、不同的行业、不同的地点以及不同的社会制度有不同的安全需求。

### 2、举例：电子交易中的安全需求



3、一般性的安全需求

(1) **机密性需求**，防止信息被泄漏给未授权的用户

自主安全策略、 强制安全策略；需知原则。

(2) **完整性需求**，防止未授权用户对信息的修改

维护系统资源在一个有效的、预期的状态，防止资源被不正确、不适当的修改；维护系统不同部分的一致性；防止在涉及记账或审计的事件中“舞弊”行为的发生。

(3) **可用性需求**，保证授权用户对系统信息的可访问性

授权用户的任何正确的输入，系统会有相应的正确的输出。

(4) **可记账性需求**，防止用户对访问过某信息或执行过某一操作以否认

可对发生的事件、操作等进行回溯。

4、安全需求的例子

| 例子             | 机密性 | 完整性 | 可记账性 | 可用性 |
|----------------|-----|-----|------|-----|
| <b>军事</b> 安全策略 | 侧重  |     |      |     |
| <b>商用</b> 安全策略 |     | 侧重  | 侧重   |     |
| <b>电信</b> 部门   |     |     |      | 侧重  |

二、什么是安全策略？

## 1、安全策略

针对面临的威胁决定采用何种对策的方法

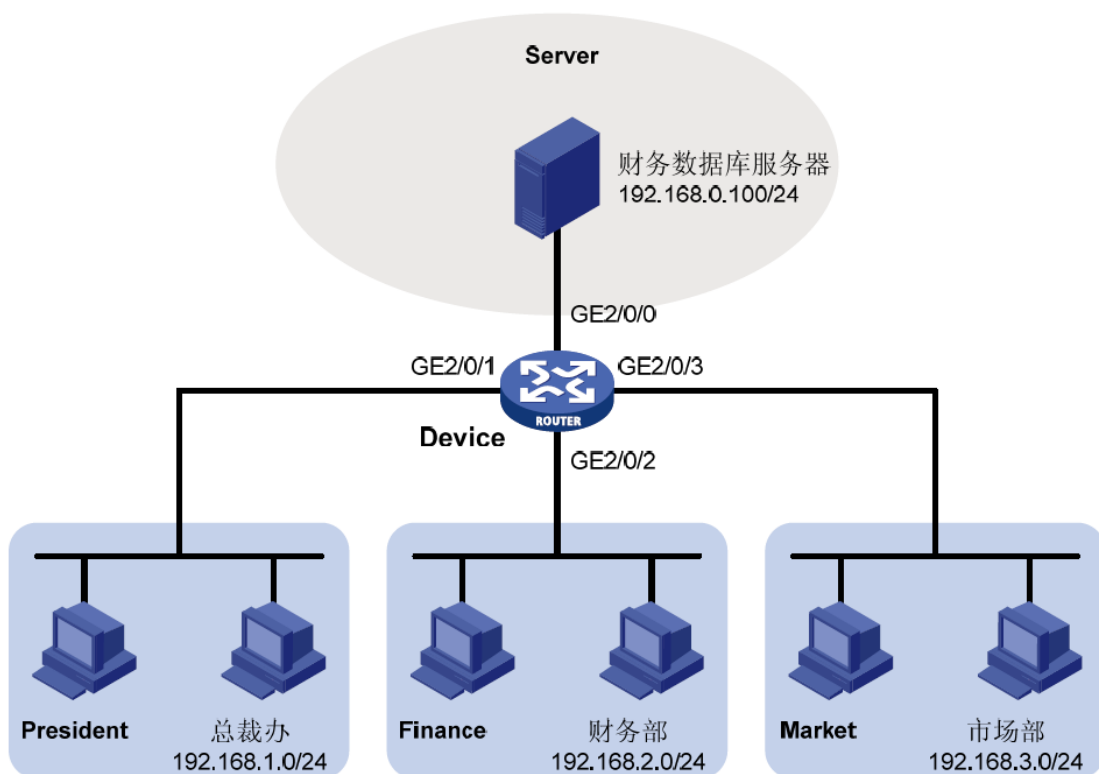
信息系统安全策略提供：信息系统保护的内容和目标，信息保护的职责落实，实施信息保护的方法，事故的处理等。

一个信息系统是“安全系统”，指的是该系统达到当初设计时所制定的安全策略的要求。

## 2、安全策略实例

(1) secpol.msc

(2) 某公司内的各部门之间通过路由器 Device 实现互连，该公司的工作时间为每周工作日的 8 点到 18 点。安全策略要求：允许总裁办在任意时间、财务部在工作时间访问财务数据库服务器，禁止其它部门在任何时间、财务部在非工作时间访问该服务器。



安全策略配置步骤：

# 创建名为 work 的时间段，其时间范围为每周工作日的 8 点到 18 点。

```
<Device> system-view
```

```
[Device] time-range work 08:00 to 18:00 working-day
```

# 创建 IPv4 高级 ACL 3000，并制订如下规则：允许总裁办在任意时间、财务部在工作时间访问财务数据库服务器，禁止其它部门在任何时间、财务部在非工作时间访问该服务器。

```
[Device] acl advanced 3000
```

```
[Device-acl-ipv4-adv-3000] rule permit ip source 192.168.1.0 0.0.0.255  
destination 192.168.0.100 0
```

```
[Device-acl-ipv4-adv-3000] rule permit ip source 192.168.2.0 0.0.0.255  
destination 192.168.0.100 0 time-range work
```

```
[Device-acl-ipv4-adv-3000] rule deny ip source any destination  
192.168.0.100 0
```

```
[Device-acl-ipv4-adv-3000] quit
```

# 应用 IPv4 高级 ACL 3000 对接口 GigabitEthernet2/0/0 出方向上的报文进行过滤

```
[Device] interface gigabitethernet 2/0/0
```

```
[Device-GigabitEthernet2/0/0] packet-filter 3000 outbound
```

```
[Device-GigabitEthernet2/0/0] quit
```

安全策略的验证：

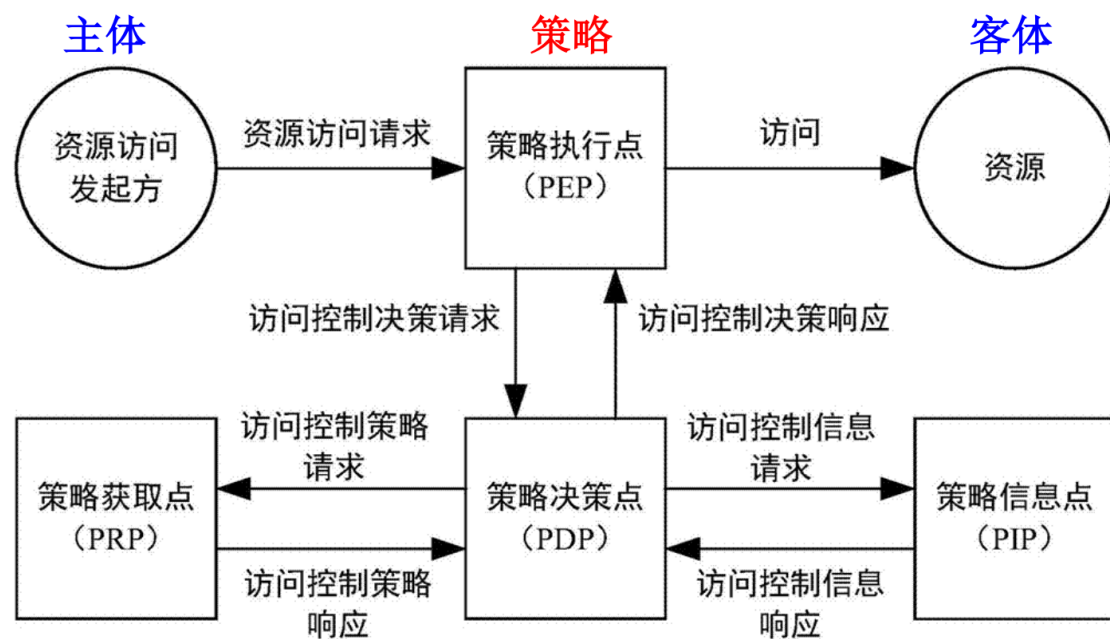
配置完成后，在各部门的 PC（假设 OS 均为 Windows 7 Pro）上可以使用 ping 命令检验配置效果，在 Device 上可以使用 display acl 命令查看 ACL 的配置和运行情况。

### 3、安全策略依据的标准

ISO/IEC 27001: 2013 Information technology—Security techniques  
—Information security management systems—Requirements

## 三、最常用的安全策略

### 1、访问控制策略



### 2、例子

(1) 用户/用户组作为主体的例子

C:\cmd.exe>compmgmt.msc

(2) 进程作为主体的例子

C:\cmd.exe>taskmgr.exe

### 3、访问控制策略的描述：访问控制矩阵



按列看是访问控制表内容

| 目标<br>用户 | 目标x     | 目标y     | 目标z     |
|----------|---------|---------|---------|
| 用户a      | R、W、Own |         | R、W、Own |
| 用户b      |         | R、W、Own |         |
| 用户c      | R       | R、W     |         |
| 用户d      | R       | R、W     |         |

按行看是访问能力表内容

#### 四、自主访问控制

##### 1、自主访问控制策略

“自主”：允许系统中信息的拥有者按照自己的意愿去指定谁可以以何种访问模式去访问该客体。

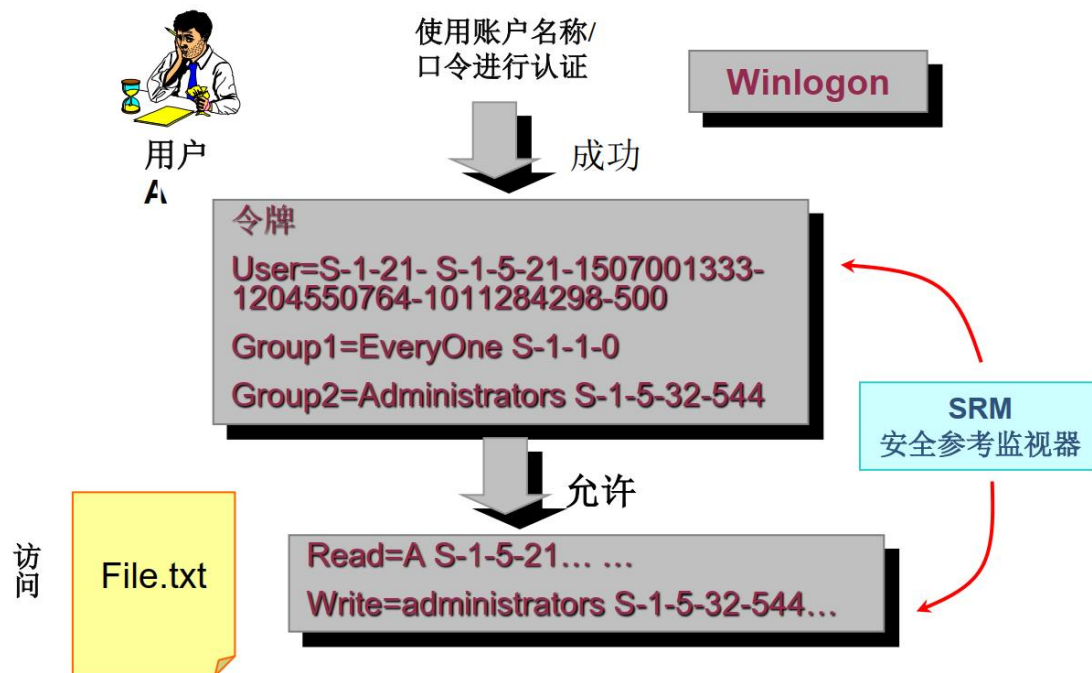
##### 2、Windows 中的访问控制模型

Windows 中的访问控制模型是 Windows 安全性的基础构件。

访问控制模型有两个主要的组成部分：访问令牌（Access Token）和安全描述符（Security Descriptor）。它们分别是访问者和被访问者拥有的东西。

通过访问令牌和安全描述符的内容，Windows 可以确定持有令牌的访问者能否访问持有安全描述符的对象。

##### 3、自主访问控制策略实例（Windows Paradigm）

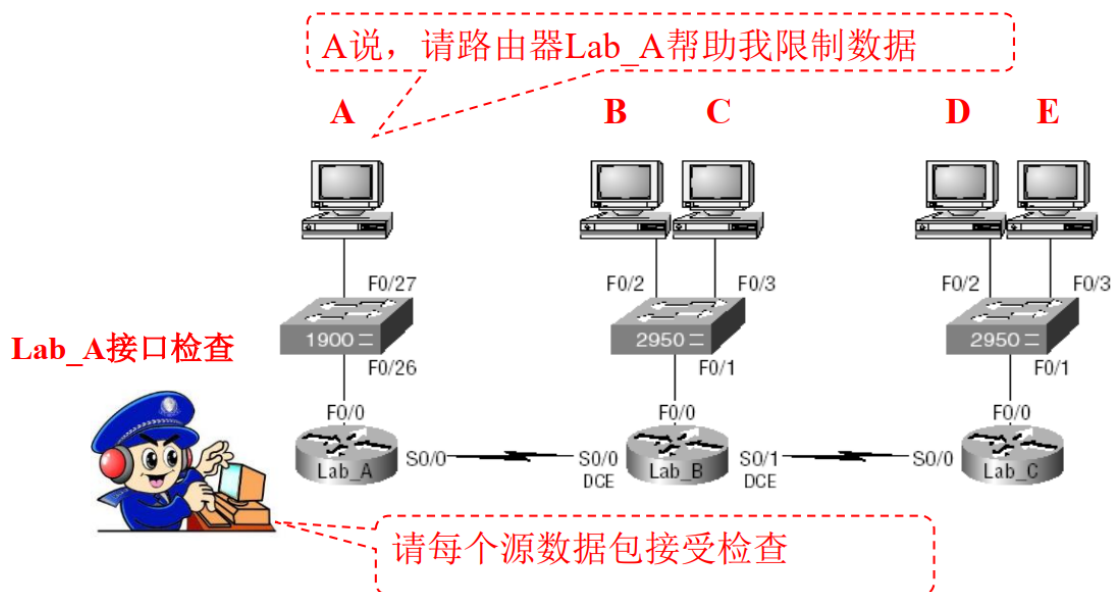


#### 4、典型的 DAC：访问控制列表

(1) 访问控制列表是一系列允许或拒绝数据的指令的集合。

(2) ACL 具有灵活的数据流过滤和控制能力。

例如，网络管理员可能允许用户访问 Internet，而不允许外部的用户登录到局域网中。



(3) 访问控制列表的分类

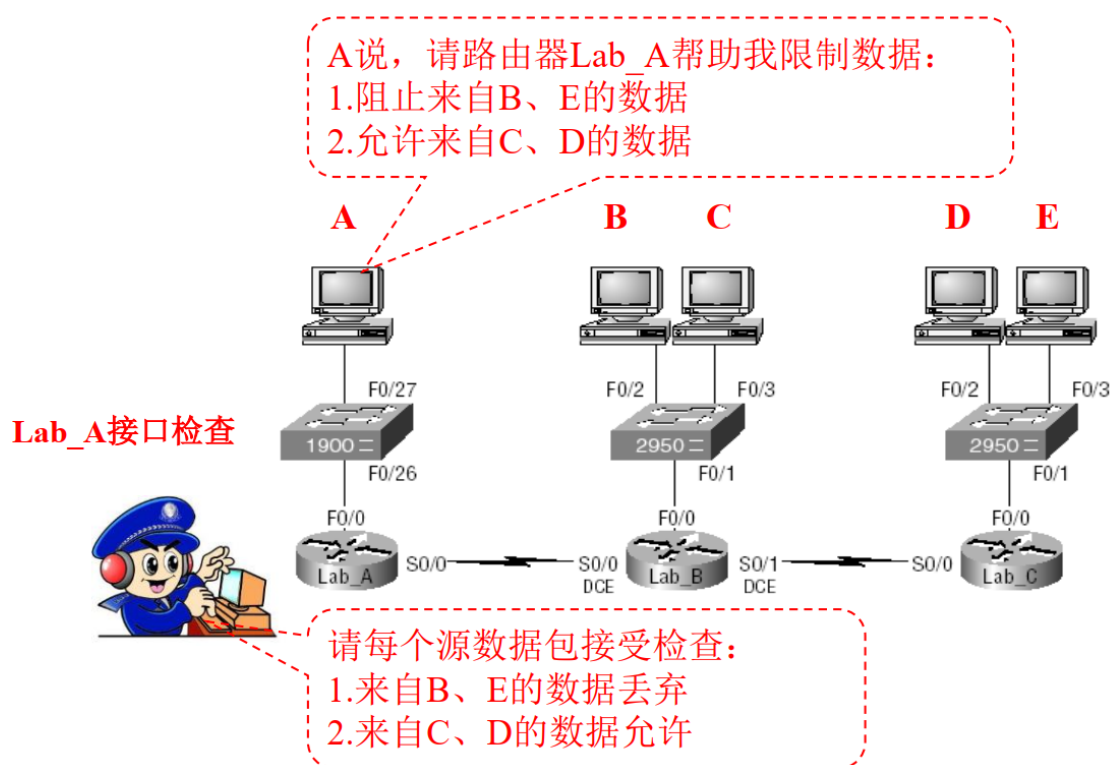
标准 ACL：只使用数据包的源地址作为测试条件。所有决定是基于源 IP 地址的。

扩展 ACL：可以测试 IP 包的第 3 层和第 4 层报头中的字段。包括源 IP 地址、目的 IP 地址、网络层报头中的协议字段（如，TCP、UDP、ICMP 等）以及位于传输层报头中的端口号。

命名 ACL：命名 ACL 以列表名代替列表编号来定义 IP 访问控制列表，同样包括标准和扩展两种列表，定义过滤的语句与编号方式中相似。

#### (4) 标准列表——基于源地址

- 标准访问列表，通过使用数据包的源 IP 地址过滤流量。
- 一般用号码区别访问列表类型可以使用访问列表号 1~99 或 1300~1999 创建标准的访问列表。



#### (5) 创建标准 ACL



创建 ACL：标准访问列表的创建根据“动作”+“源地址”，即允许谁、拒绝谁的方法来创建。

```
Router(config)#access-list access-list-number  
{ permit | deny } source [ source-wildcard ]
```

允许数据包通过  
拒绝数据包通过

删除 ACL：

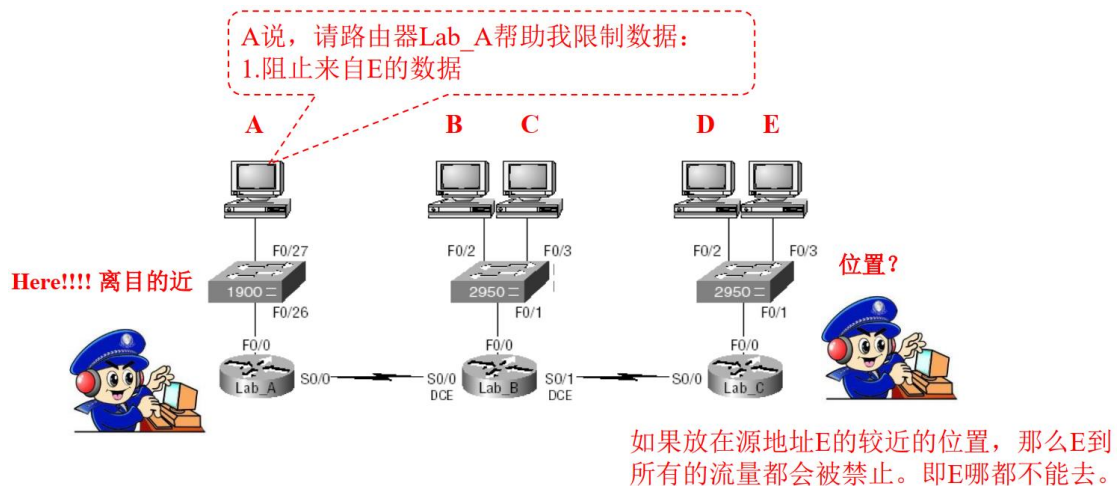
```
Router(config)# no access-list access-list-number
```

创建标准 ACL 实例：

```
Router(config)# access-list 1 permit 192.168.1.0 0.0.0.255  
Router(config)# access-list 1 permit 192.168.2.2 0.0.0.0
```

允许 192.168.1.0/24 和主机 192.168.2.2 的流量通过。

#### (6) 标准列表——靠近目的地址



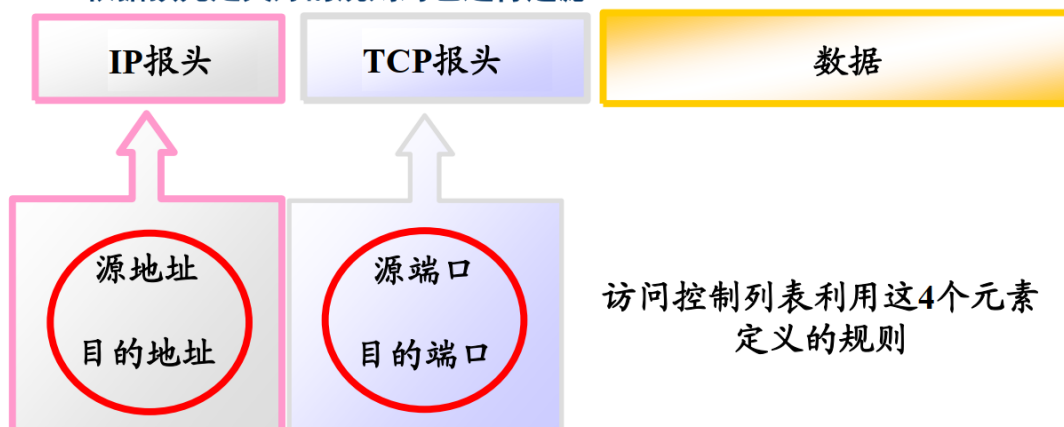
(7) 扩展列表——基于源地址、目的地址、协议、端口

访问控制列表 (ACL)

- 读取第三层、第四层包头信息
- 根据预先定义好的规则对包进行过滤

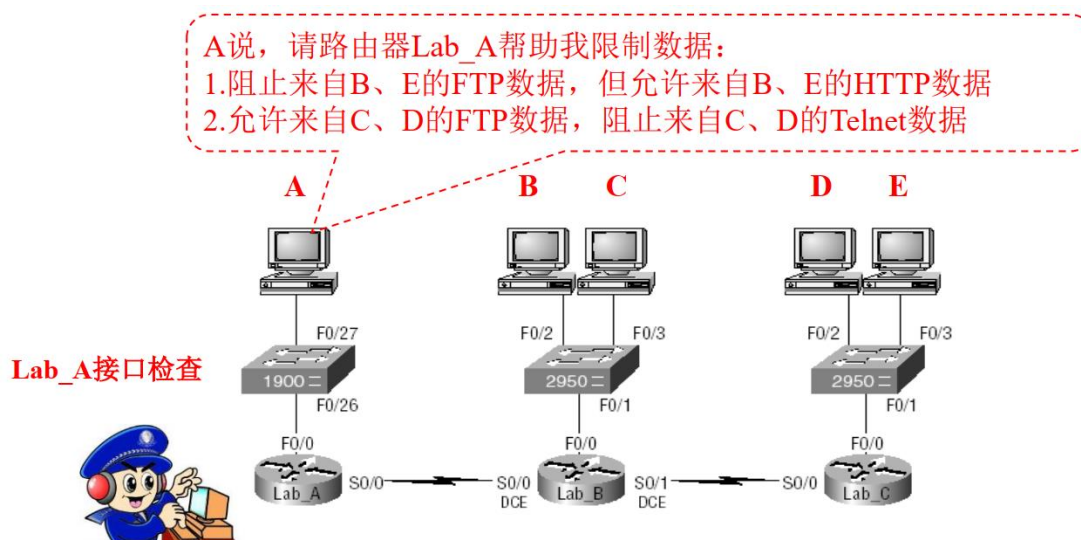
#### ❖ 访问控制列表 (ACL)

- 读取第三层、第四层包头信息
- 根据预先定义好的规则对包进行过滤



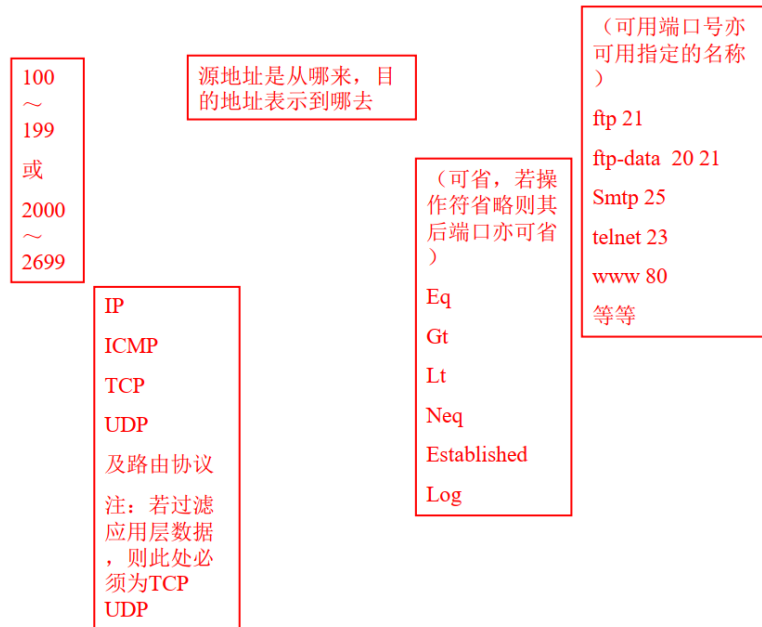
扩展访问列表具有在控制流量时做更细粒度决定的能力。

扩展 ACL 的 ID 号为 100~199 或 2000~2699。



## (8) 扩展 ACL 的创建命令

**Lab\_A(config)#access-list ID号 协议 源地址 目的地址 操作符 端口/服务类型**



Examples: 扩展 ACL

```
Lab_A(config)#access-list 110 deny tcp any host 172.16.30.2 eq www
```

含义：拒绝任何 IP 地址通过 TCP 协议访问主机 172.16.30.2 的 www 服务。隐含的意思是主机可以访问 172.16.30.2 的其它服务，限制更为细致。

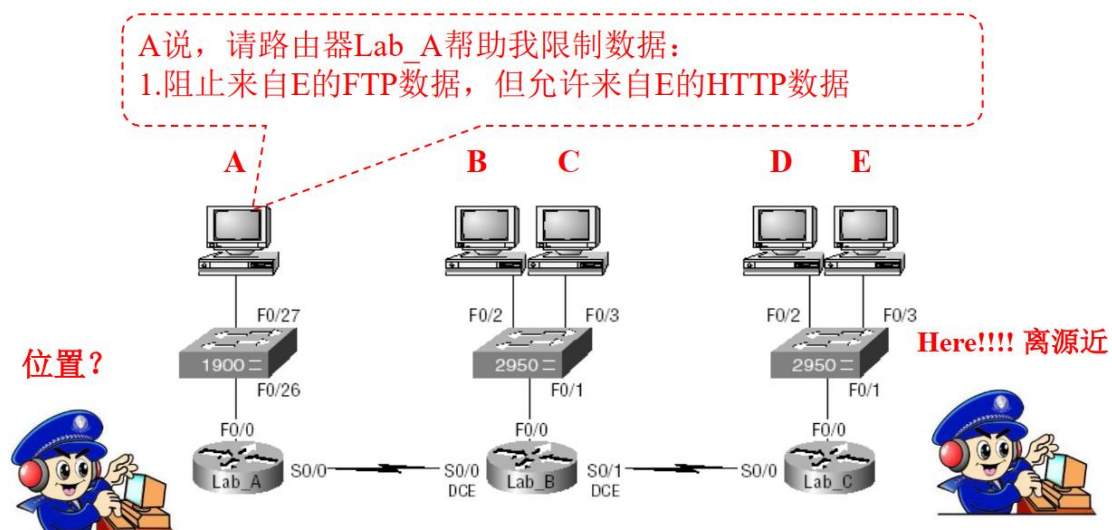
```
Lab_A(config)#access-list 110 permit tcp 192.168.10.0 0.0.0.255 host 172.16.30.2 eq 23 log
```

含义：允许网段 192.168.10.0 255.255.255.0 通过 TCP 协议访问主机 172.16.30.2 的 23 端口的服务即 Telnet 服务，记录访问日志。

```
Lab_A(config)#access-list 110 permit ip any any
```

含义：允许所有使用 IP 协议的 IP 访问其它所有 IP，即允许所有。

## (9) 扩展列表的放置——靠近源地址



如果放在离目的地址 A 较近的位置，那么 E 到 A 的 FTP 流量将会穿过整个网络，在到达目的地的时候却被告知不可以到达，浪费网络带宽。即 E 的 FTP 流量白传播一趟。

(10) 如果要屏蔽来自 192.168.0.0/24 192.168.2.0/24 网段的所有 ICMP 数据包，怎么设置 ACL?

以批处理的方式，自动进行

```
Router(config)# access-list 10 permit any any
```

## 5、通配掩码

### (1) 通配掩码

路由器使用 IP 地址和通配掩码 (wildcard-mask) 一起来分辨匹配的地址范围，它跟子网掩码刚好相反。

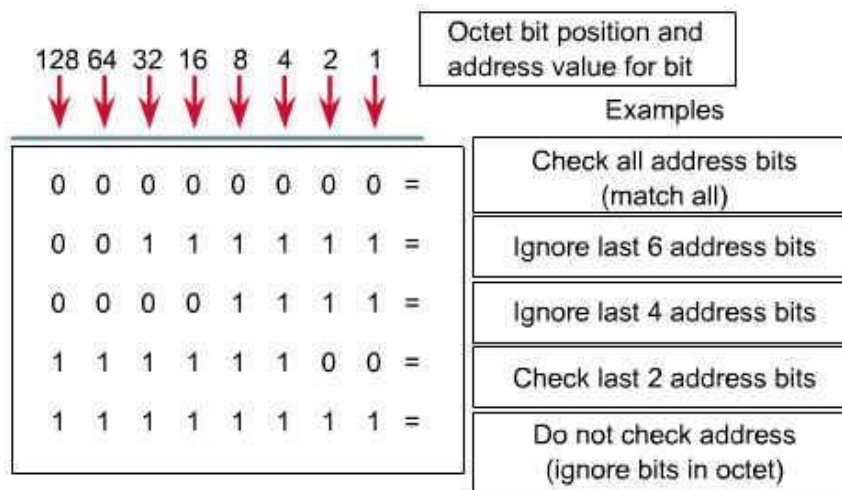
- 它不像子网掩码告诉路由器 IP 地址的哪一位属于网络号一样，通配符掩码告诉路由器为了判断出匹配，它需要检查 IP 地址中的多少位。

- 有了通配掩码，可以只使用两个 32 位的号码来确定 IP 地址的范围，这是十分方便的！

如果没有掩码的话，不得不对每个匹配的 IP 地址加入一个单独的 ACL 语句。这将造成很多额外的输入和路由器大量额外的处理过程。所以地址掩码相当有用！

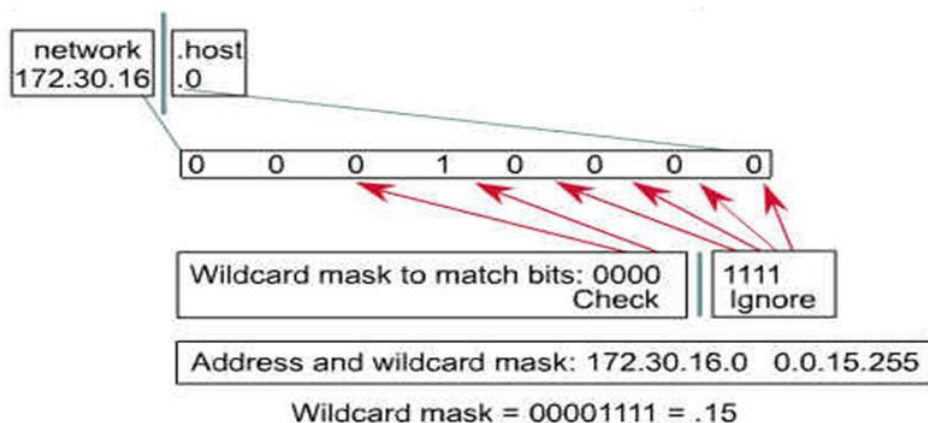
- 通配掩码 (wildcard mask) 是分成 4 字节的 32bit 数
- 通配掩码与 IP 地址位位配对，相应位为 0/1，用于表示如何对待 IP 地址中的相应位。通配掩码某位是 0 表示检查相应 bit 位的值，通配掩码某位是 1 表示不检查（忽略）相应位的值。

### (2) 通配掩码的工作原理



### (3) 通配掩码举例

假设一个 B 类地址，有 16 位子网地址。想使用通配掩码，允许所有来自于网络 172.30.16.0~172.30.31.0 的数据报访问。



→ 首先，检查前面两个字节（171.30），通配掩码中的前两个字节位全为 0。

→ 由于没有兴趣检查主机地址，通配掩码的最后一个字节位全为 1。

#### (4) any——通配符特殊应用

在路由器中谈到默认路由时使用的地址是：

```
ip route 0.0.0.0 0.0.0.0 192.168.0.2
```

➤ 其中 0.0.0.0 0.0.0.0 表示任意网络地址，其子网掩码 0.0.0.0 表示不对任何地址做匹配

➤ 在 ACL 中如果要表示任意地址，也可用此种形式。不过通配符因为  $0.0.0.0 = 255.255.255.255$ 。即 ACL 中 0.0.0.0 255.255.255.255 表示任意地址。但有时书写较为麻烦，可以用单词 any 替代。

➤ 即 any 与 0.0.0.0 255.255.255.255 均表示任意地址

→ Router(config)# access-list 1 permit 0.0.0.0 255.255.255.255

等价于

→ Router(config)# access-list 1 permit any

#### (5) host——通配符特殊应用

同样在路由器章节中，设置环回接口地址时，使用 255.255.255.255 的子网掩码，我们称此为主机掩码，表示此网络中只有一个给主机使用的地址。如，192.168.0.1 255.255.255.255。

ACL 中的主机地址可以为 192.168.0.1 0.0.0.0

同样，可以简化输入使用单词 host 替代。注：在使用主机地址的时候单词 host 也可省略。即

→ Router(config)# access-list 1 permit 171.30.16.29 0.0.0.0

等价于

→ Router(config)# access-list 1 permit host 171.30.16.29

## 6、自主访问控制的优缺点

### ❖ 自主访问控制的优点

➤ 访问模式设定灵活。

- 读；写；执行；“每隔一周的周五可以读”；“读完文件 x 后才能读此文件”等等；

➤ 具有较好的适应性，常用于商用 OS 和应用中。

### ❖ 自主访问控制的缺点

➤ 不能防范木马和某些形式的恶意代码。

➤ 思考：一个用户的程序中隐藏了木马，将会如何？

## 五、强制访问控制

### ❖ 经典场景：军事机密及其管理

➤ 无密级；保密；机密；绝密。

### ❖ 强制访问控制，基于上述原型而来

➤ 主体/客体：贴上标签

➤ 引用监视器：比较标签，决定是否许可

❖ 效果：保证完整性或机密性

在强制访问控制系统中，所有主体（用户，进程）和客体（文件，数据）都被分配了安全标签，安全标签标识一个安全等级。

- 主体（用户，进程）被分配一个安全等级
- 客体（文件，数据）也被分配一个安全等级
- 访问控制执行时对主体和客体的安全级别进行比较



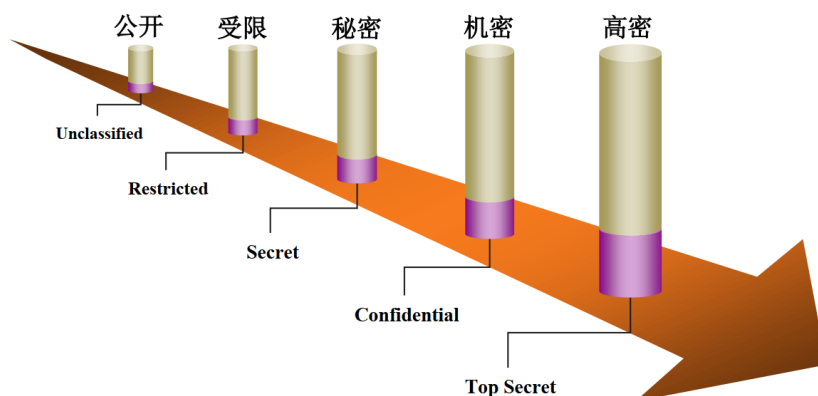
## 1、Bell-LaPadula 模型

Bell-LaPadula 保密性模型是第一个能够提供分级别数据机密性保障的安全策略模型（多级安全）。

该模型基于强制访问控制系统，以敏感度来划分资源的安全级别。将数据划分为多安全级别与敏感度的系统（称之为多级安全系统）。

Bell-LaPadula (BLP) 安全模型对主体和客体按照强制访问控制系统的思想进行分类，这种分类方法一般应用于军事用途。

### (1) 数据和用户被划分为五个安全等级





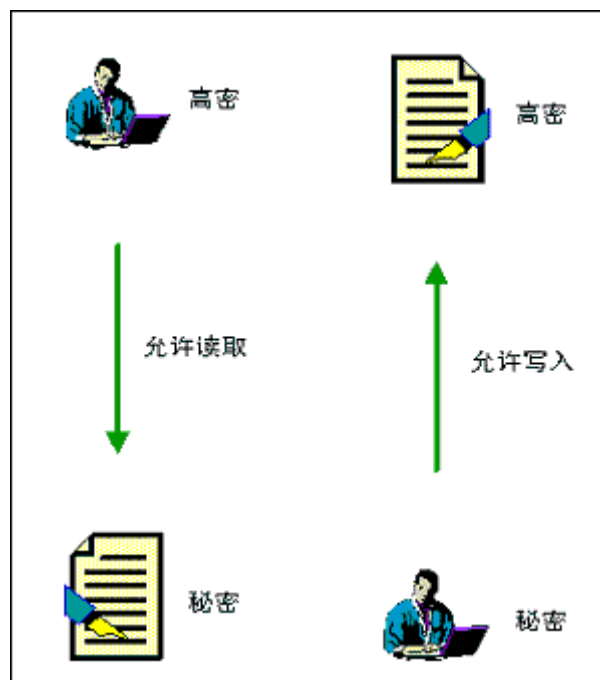
(2) BLP 保密模型基于两种规则来保障数据的机密度与敏感度：

- 不上读 (NRU) —主体不可读安全级别高于它的数据
- 不下写 (NWD) —主体不可写安全级别低于它的数据

BLP 模型允许用户读取安全级别比他低的资源；相反地，写入对象的安全级别只能高于用户级别。

### (3) 举例

- 安全级别为“高密”的用户在访问安全级别为“秘密”的文档时，将能够成功读取该文件，但不能写入；
- 安全级别为“秘密”的用户不能访问安全级别为“高密”的文档，但能够写入。
- 这样，文档的保密性就得到了保障。

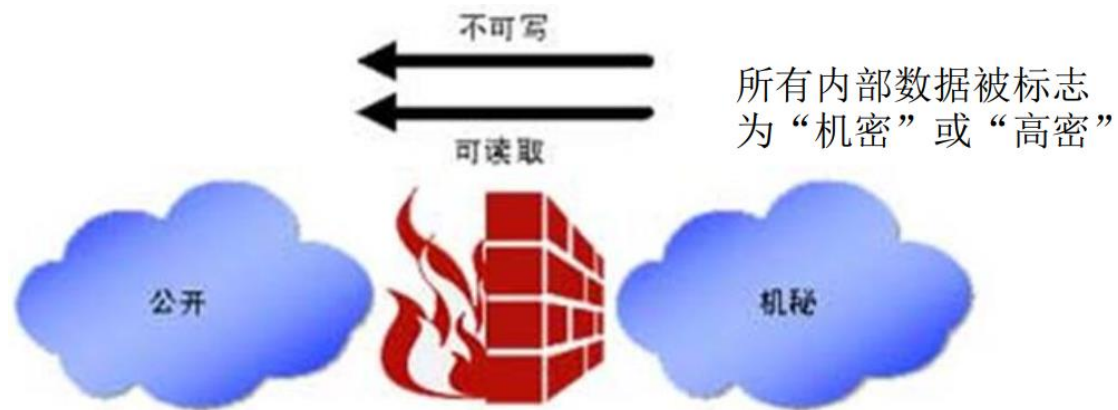


### (4) 防火墙所实现的单向访问机制

防火墙所实现的单向访问机制不允许敏感数据从内部网络（例如，其安全级别为“机密”）流向 Internet（安全级别为“公开”）。

➤ 防火墙提供“不上读”功能来阻止 Internet 对内部网络的访问；

➤ 提供“不下写”功能来限制进入内部的数据流只能经由由内向外发起的连接流入（例如，允许 HTTP 的“GET”操作而拒绝“POST”操作，或阻止任何外发的邮件）。



## 2、BIBA 完整性模型

该模型对数据提供了分级别的完整性保证，类似于 BLP 保密性模型，BIBA 模型也使用强制访问控制系统。

BIBA 完整性模型对主体和客体按照强制访问控制系统的思想进行分类，这种分类方法一般应用于军事用途。

(1) BIBA 模型基于两种规则来保障数据的完整性的保密性：

- 不下读 (NRU) 属性主体不能读取安全级别低于它的数据
- 不上写 (NWD) 属性主体不能写入安全级别高于它的数据

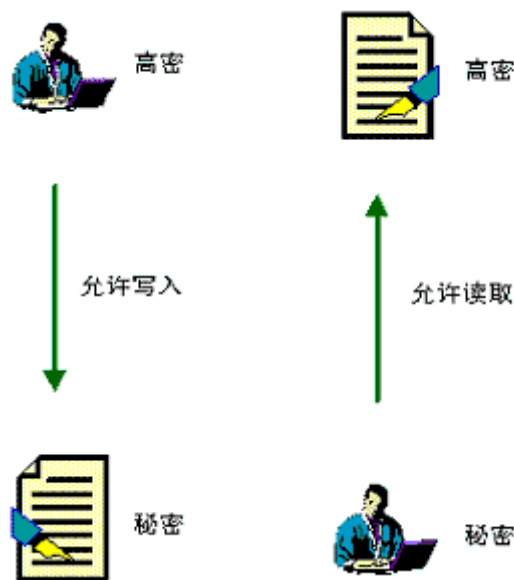
(2) 从这两个属性来看，BIBA 与 BLP 模型的两个属性是相反的：

- BLP 模型提供保密性；
- BIBA 模型对于数据的完整性提供保障。

BIBA 模型并没有被用来设计安全操作系统，但大多数完整性保障机制都基于 BIBA 模型的两个基本属性构建。

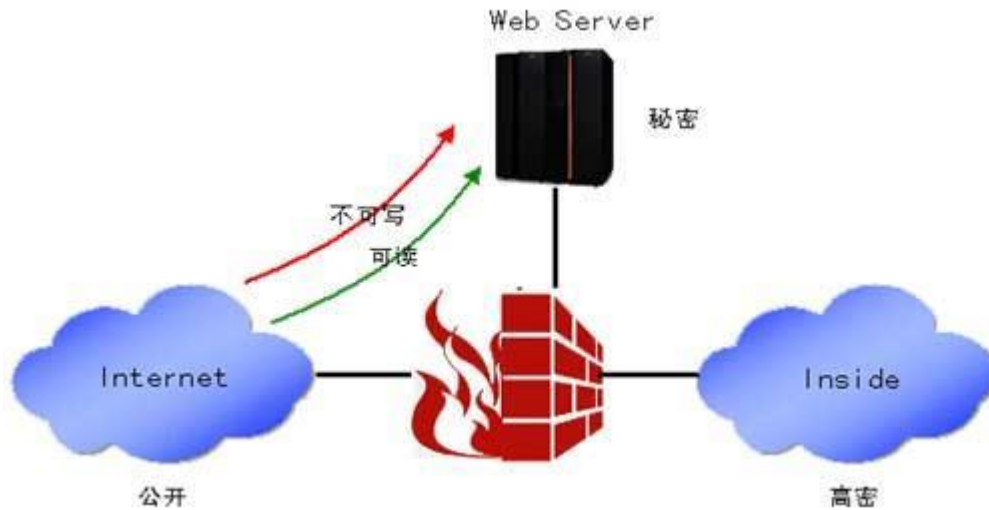
### (3) 举例

只有用户的安全级别高于资源的安全级别时可对资源进行写操作。相反地，只有用户的安全级别低于资源的安全级别时可读取该资源。



### (4) Biba 完整性模型的应用

Internet 上用户的安全级别为“公开”，依照 BIBA 模型，Web 服务器上数据的完整性将得到保障，Internet 上的用户只能读取服务器上的数据而不能更改它。因此，任何 POST 操作将被拒绝。



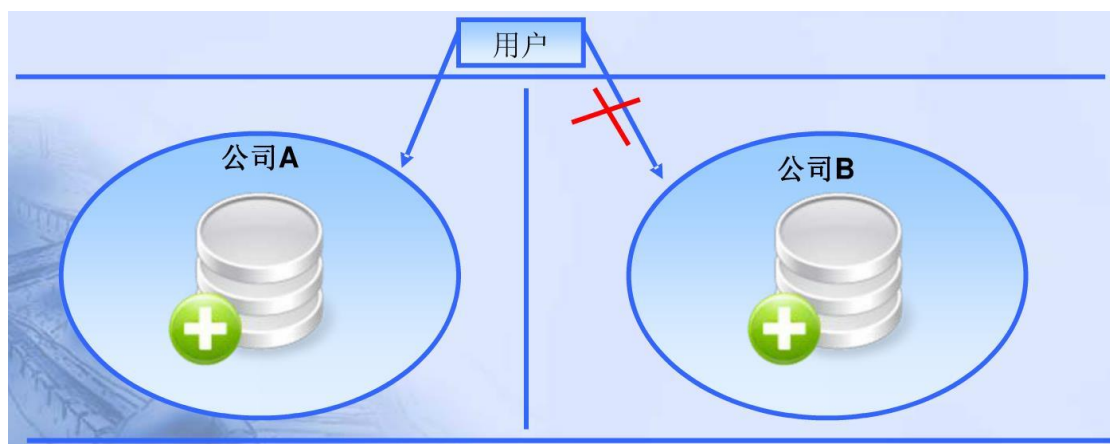
### (5) Chinese Wall 模型

Chinese Wall 模型应用在多边安全系统中（也就是多个组织间的访问控制系统），目标主要就是防止利益冲突的发生。

Chinese Wall 模型的主要功能是防止用户访问被认为是存在利益冲突的数据。

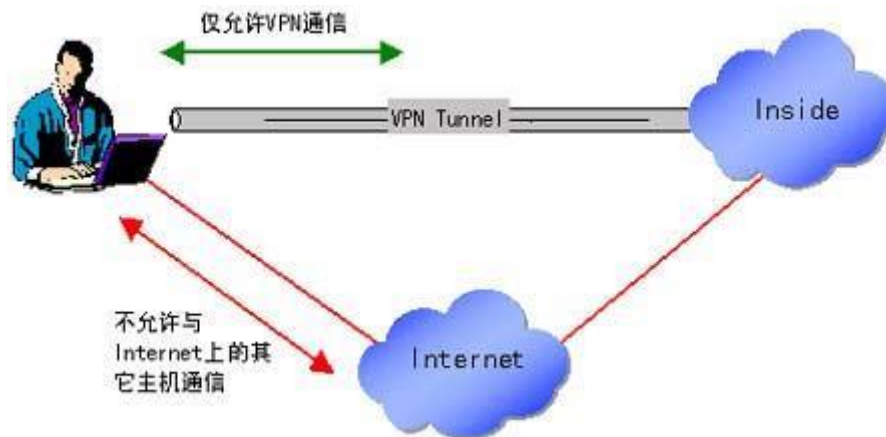
Chinese Wall 安全策略的基础是客户访问的信息不会与目前他们可支配的信息产生冲突。

信息被分组成若干利益冲突的类，一个人在每个类中至多允许访问一组信息。



Chinese Wall 安全模型的应用：远程访问 VPN

单向会话只发生在有限的时间内，本安全模型的核心在于：用户选择与其中一方进行通信，则放弃了与另一方会话的权利。



#### (6) 最显著的特征：全局性和永久性

- 无论何时何地，主体和客体的标签是不会改变的。
- **全局性**：对特定的信息，从任何地方访问，它的敏感级别相同。
- **永久性**：对特定的信息，在任何时间访问，它的敏感级别相同。

上述特征在多级安全体系中称为“宁静性原则”（tranquility），一旦不满足该原则，无法从根本上防备木马和恶意代码。

### 3、思考题

是否可以设计一种基于Bell-LaPadula模型和BIBA模型的混合模型，从而既能保护数据的机密性，又能保证其完整性？



SSR模型和BLP、BIBA模型一样，通过安全标签的方式实现用户级别的强制访问控制，所不同的是标签安全中级别和级别的访问控制模型方案。**SSR安全模型侧重于更强的完整性和保密性要求同时满足。**

此安全模型由浪潮嘉信公司提出并应用于其服务器安全加固系统中。

SSR的访问控制为：  
允许同级别的主体对客体享有所有权限；  
高级别主体对低级别客体有只读权限；  
低级别主体对高于自己级别的客体没有任何权限。